Durham University

Applied security (COMP3761)
Digital forensics

Prof David Oswald & Dr Charles Morisset

david.f.oswald@durham.ac.uk

MCS1033

Plan for today

- Understand the basics of forensics
- Both from the technical side …
- … and also touching on laws and best practices

Durham University

Why digital forensics?

Example 1: Dealing with a security incident

KASPERSKY lab

INITIAL ATTACK

The initial attack against Kaspersky Lab began with the targeting of an employee in one of our smaller APAC offices. The original infection vector for Duqu 2.0 is currently unknown, although we suspect spear-phishing e-mails played an important role. This is because for one of the patients zero we identified had their mailbox and web browser history wiped to hide traces of the attack. Since the respective machines were fully patched, we believe a zero-day exploit was used.

In 2011, we were able to identify Duqu attacks that used Word Documents containing an exploit for a zero-day vulnerability (CVE-2011-3402) that relied on a malicious embedded TTF (True Type Font File). This exploit allowed the attackers to jump directly into Kernel mode from a Word Document, a very powerful, extremely rare, technique. A similar technique and zero-day exploit ([4]CVE-2014-4148) appeared again in June 2014, as part of an attack against a prominent international organization. The C&C server used in this 2014 attack as well as other factors have certain similarities with Duqu, however, the malware is different from both Duqu and Duqu 2.0. It is possible that this is a parallel project from the Duqu group and the same zero-day (CVE-2014-4148) might have been used to install Duqu 2.0.

Example 2: Police investigations



http://www.ntnews.com.au/news/northern-territory/northern-territory-police-fraud-squad-seize-computers-and-documentation-from-darwin-travel-agency/story-fnk0b1zt-1227171355287

Durham University

German cyber-attack: man admits massive data breach, say police

A 20-year-old man has admitted to police that he was behind one of the country's biggest data breaches, in which the private details of almost 1,000 public figures were leaked.

The man, who lives with his parents in the central German state of Hesse and is still in the education system, told police he had acted alone and was not politically motivated.

He told investigators he had been driven instead by his annoyance at statements made by the victims of his attacks, including politicians, journalists and leading celebrities.



The hacker, who used the pseudonyms "G0t" and "Orbit", was arrested on Sunday after investigators searched his home. On Monday, he confessed to the cyber-attack, prosecutors said. He is accused of spying, leaking data and the unwarranted publication of personal data.

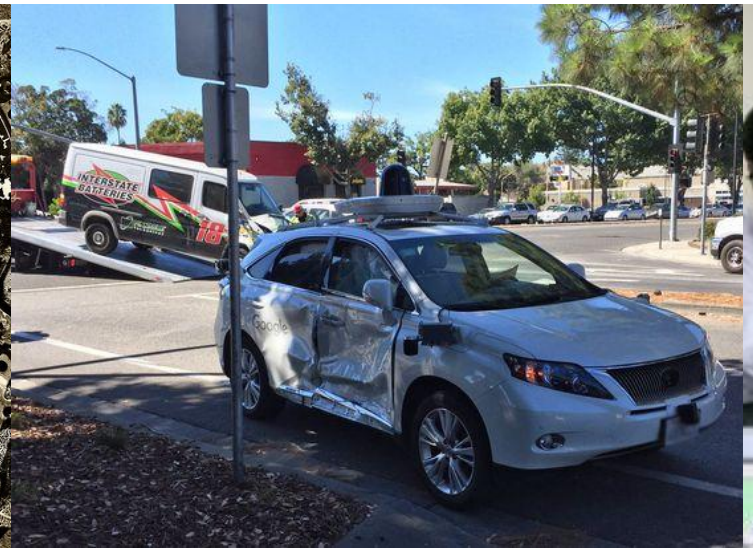
Investigators traced the man through digital tracks he left on the internet, as well as by speaking to witnesses, including a 19-year-old man with whom the hacker had communicated via an encrypted messaging service. The hacker told him he had destroyed his computer to avoid detection, but police said they had recovered extensive evidence.

https://www.theguardian.com/world/2019/jan/08/germany-data-breach-man-held-in-suspected-hacking-case

Other examples and related areas

- Analysing actions of (unknown) malware
- Data recovery from damaged systems
- Understanding hardware and software faults
- Penetration testing (e.g. OS security)







Durham University

Digital forensics in the UK

- ACPO: “Good Practice Guide for Digital Evidence”
  (ACPO = Association of Chief Police Officers)
  - Mostly oriented towards law enforcement
  - Collection of best practices, not necessarily legally binding
- Forensic Science Regulator: codes of practice and conduct:
  https://assets.publishing.service.gov.uk/media/68401f4be550203c8209cce9/2025_05_20_Code_of_Practice_final.pdf

ACPO guide & principles

2. SECTION 2 – THE PRINCIPLES OF DIGITAL EVIDENCE

2.1 PRINCIPLES

2.1.1 **Principle 1:** No action taken by law enforcement agencies, persons employed within those agencies or their agents should change data which may subsequently be relied upon in court.

2.1.2 **Principle 2:** In circumstances where a person finds it necessary to access original data, that person must be competent to do so and be able to give evidence explaining the relevance and the implications of their actions.

2.1.3 **Principle 3:** An audit trail or other record of all processes applied to digital evidence should be created and preserved. An independent third party should be able to examine those processes and achieve the same result.

2.1.4 **Principle 4:** The person in charge of the investigation has overall responsibility for ensuring that the law and these principles are adhered to.

2.2 EXPLANATION OF THE PRINCIPLES

https://npcc.police.uk/documents/crime/2014/Revised%20Good%20Practice%20Guide%20for%20Digital%20Evidence_Vers%205_Oct%202011_Website.pdf

PCI PFI Program Guide

Appendix A: Forensic Investigation Guidelines

In accordance with applicable Industry Rules, a Compromised Entity that stores, processes, or transmits payment card data and is the subject of a Security Issue must ensure that only a PCI Forensic Investigator approved under the PCI SSC PFI Program is engaged to perform a forensic investigation thereof. All PFIs are required to adhere to the following forensic investigation guidelines in all PFI Investigations. Compromised Entities can also use these guidelines to monitor the work of the PFI.

PFI Investigations must be conducted using the following scope and methodology:

1. The PFI will determine the scope of the forensic investigation and relevant sources of electronic evidence. This includes, but is not limited to:
    - Assessment of all external and internal connectivity points within each location involved.
    - Assessment of network access controls between compromised system(s) and adjacent and surrounding networks.
2. The PFI will acquire electronic evidence from the Compromised Entity's host and network-based systems.

https://www.pcisecuritystandards.org/documents/PFI_Program_Guide_2.1.pdf

Main areas

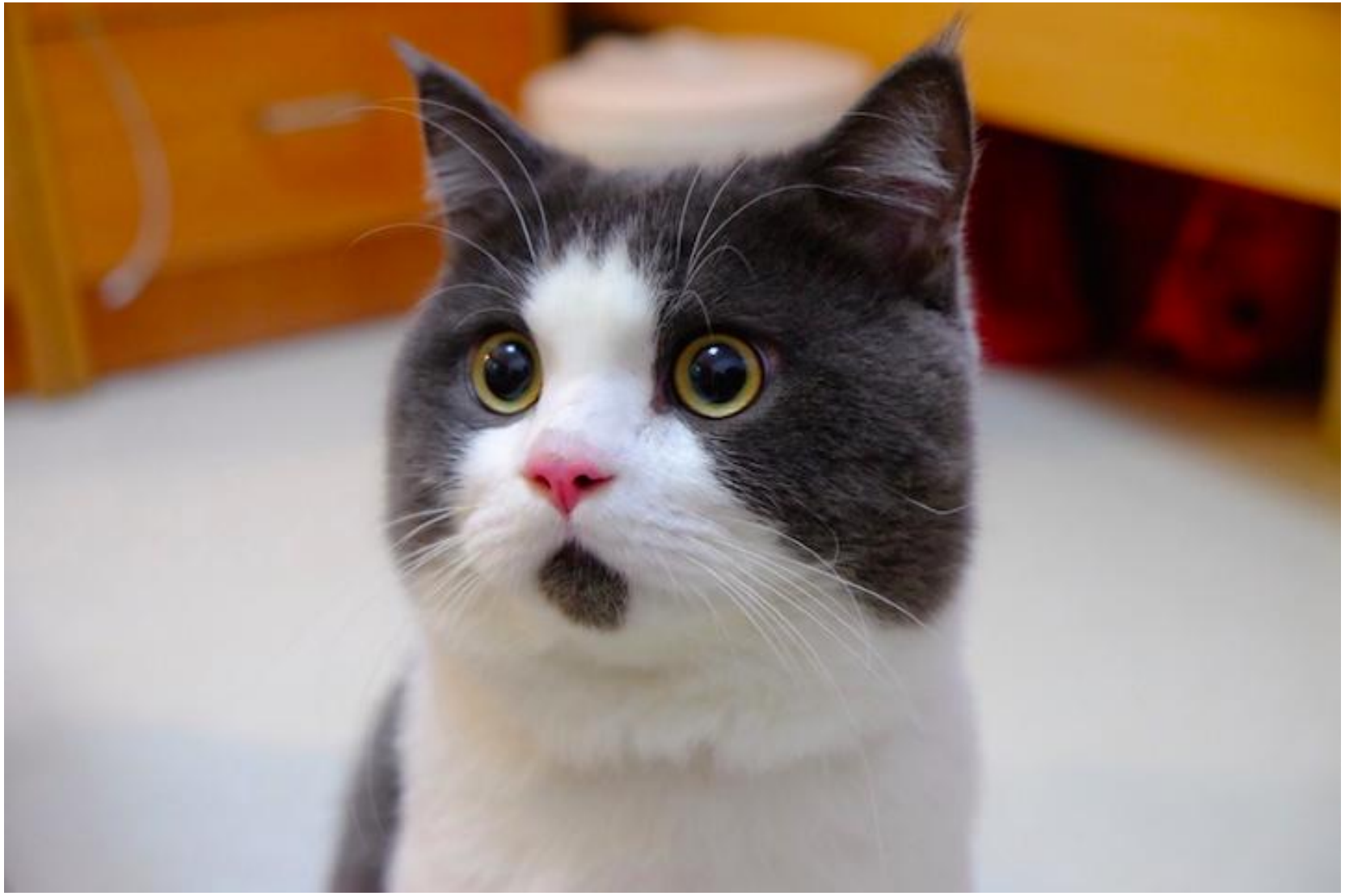
- Disk forensics
- File forensics
- Memory forensics
- Log file forensics
- Network forensics







Disk and file forensics: what?



Durham University

Filesystems vs. block devices

Filesystem

- View on storage resources
- Stores contents of objects (files, dirs) with associated metadata
- Deleted files not visible

Block device

- Visible as a list of blocks to the operating system
- Usually supports random access
- May have “weird” properties for access times
- Deleted data can remain in orphan blocks

File system forensics

- **Main goal:** Determine what is *currently* stored in a filesystem
- Determine how and when that state was created
- Possibly determine *previous* contents of the storage
- Make sure this state was not fabricated
- Look for anomalies in the system
- DO NOT MODIFY ANYTHING (and keep log if unavoidable)



Really forbidden!!!

How NOT to do it

- ~~Boot the machine, copy all files to USB disk~~
- ~~Put the disk(s) into second PC, mount filesystem, copy files~~
- ~~Put the disk(s) into second PC (running "normal" OS), mount, take image~~

Durham University

How to DO it: Common practice

- Shut the powered system down
- Document state of the system, peripherals, serial numbers, location, date/time, internal connection of disks
- Remove hard disks
- Use a hardware write blocker
- Use a second system to take the image with dedicated software
- Take an image of each disk separately
- Store hash of the image, write it down / print
- Run your full analysis only on the images you took, reassemble RAID or similar storage in software

Read-only access to a filesystem

- Just don’t modify something willingly
  (Your operating system will still modify the access time of the files)
- Mount the filesystem read-only
  (might still trigger something like auto-defragmentation)
- Use write-barriers on the operating system
  (The OS might still change power-management settings on the storage)
- Add a hardware write blocker
  (A hardware RAID controller after the blocker might start a rebuild)
- Bypass hardware RAID controller, take images
  (The disk itself might still start to shuffle around free/unused blocks)
- Bypass storage controller on the hardware
  (That’s pretty good, but often difficult)

Write blockers

- Prevents writes to a medium being imaged by filtering respective commands
- Often directly combined with imaging options
- Example: Tableau TX1 (https://www.guidancesoftware.com/tableau/hardware/tx1)



BROAD MEDIA SUPPORT



The TX1 can forensically image a broad range of media, including PCIe and 10Gb Ethernet devices, and supports up to two active forensic jobs at a time (simultaneous imaging). When imaging, TX1 outputs to raw .DD and .dmg formats, .e01 (compressed), or .ex01 (compressed), and features extensive file system support (ExFAT, NTFS, EXT4, FAT32, HFS+).



An example: imaging mobile devices

Imaging mobile storage is **hard**:

- Shut down – you lose access to device due to encryption, PIN etc.
- Remove drive – Flash memory usually integrated on PCB, encrypted
- Connect to write blocker – not readily available for Flash as used in smartphones
- **What to do?**

Should follow a standard forensics procedure:

- Documentation
- Isolation (beware of remote wipe)
- Acquisition (and hashing)



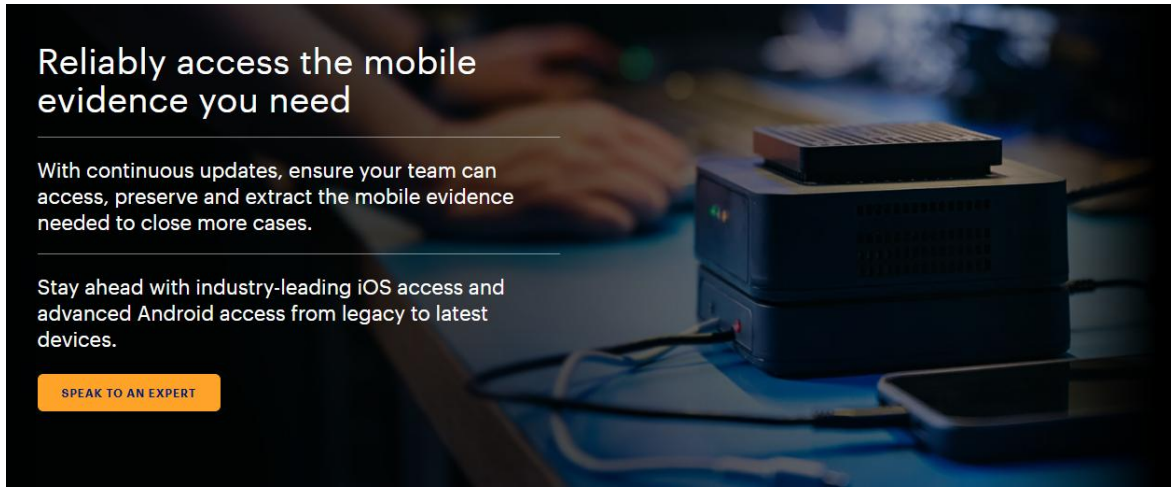
Imaging mobile devices

No single correct way to image a mobile device, but multiple options

- *Manual:* inspect live device through UI
- *Backups:* offline (e.g. iTunes) or cloud
- *Logical:* dump through external interface, e.g. USB
- *Jailbreak OS:* obtain root rights, then image
- *Low-level exploits*, e.g. before OS boots
- *Physical:* open device, connect to JTAG or remove/read Flash memory

In practice: well-equipped lab would most likely use specialized tools, e.g. Cellebrite UFED, Magnet GrayKey, …

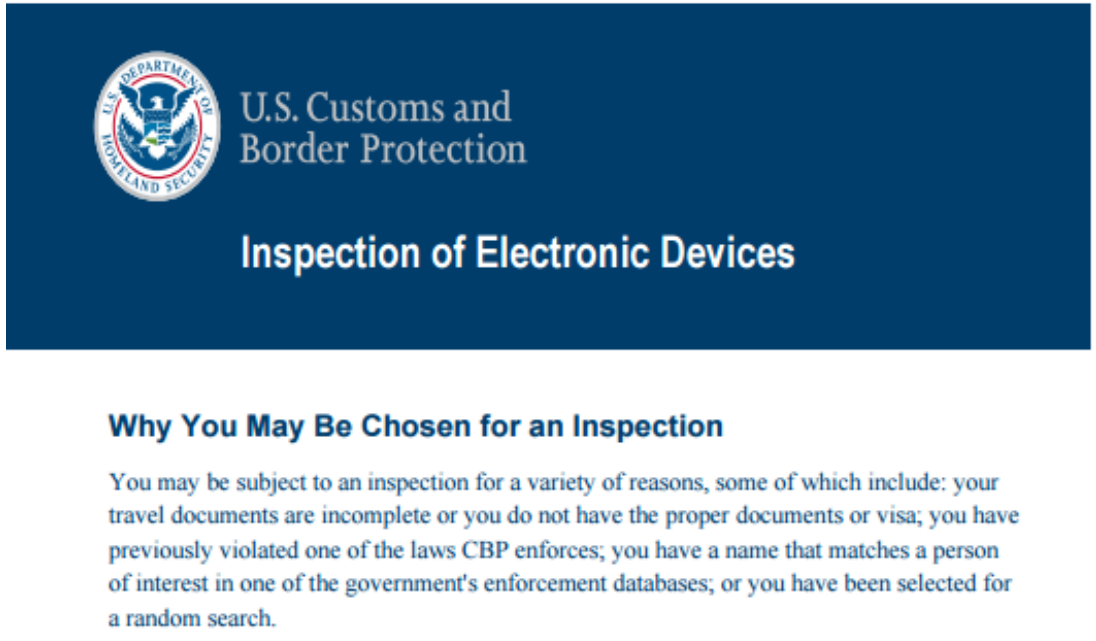
https://www.magnetforensics.com/products/magnet-graykey/



Durham University

Disclosure laws

https://www.cbp.gov/sites/default/files/documents/inspection-electronic-devices-tearsheet.pdf



U.S. Customs and Border Protection

Inspection of Electronic Devices

Why You May Be Chosen for an Inspection

You may be subject to an inspection for a variety of reasons, some of which include: your travel documents are incomplete or you do not have the proper documents or visa; you have previously violated one of the laws CBP enforces; you have a name that matches a person of interest in one of the government's enforcement databases; or you have been selected for a random search.

"The Regulation of Investigatory Powers Act 2000 requires persons to decrypt information and/or supply keys to government representatives to decrypt information without a court order."

https://en.wikipedia.org/wiki/Key_disclosure_law

Analysing disk images



Durham University

Analysing disk images

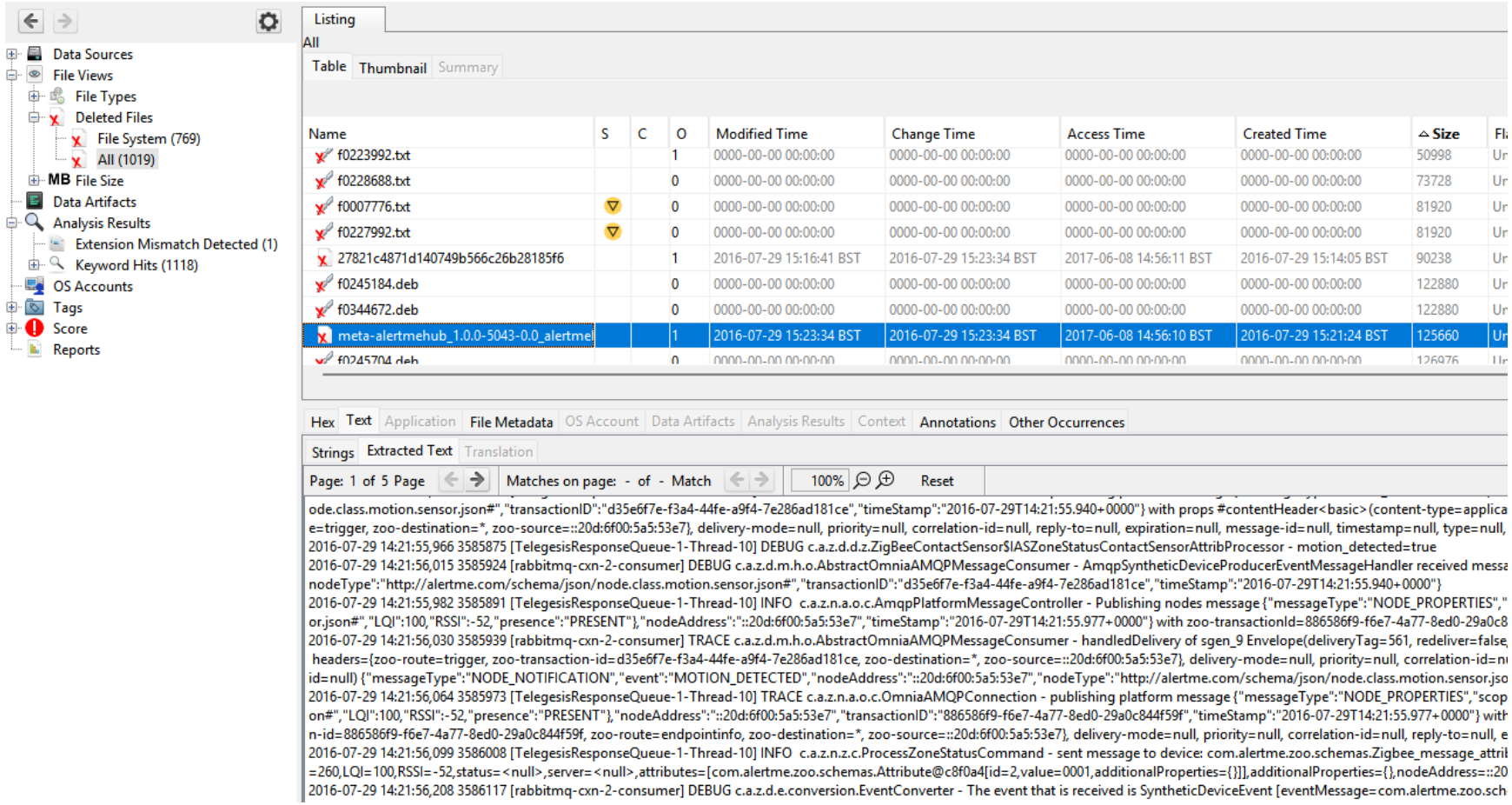
1. Hash & backup the image
2. Reorder physical drives to logical groups (RAID, LVM) if necessary
3. Recover partition tables
4. Identify file systems
5. Determine content of file systems
6. Check for “interesting” files
7. Create a timeline of events
8. Check for possibly deleted files
9. Check for anomalies

File forensics (overview)

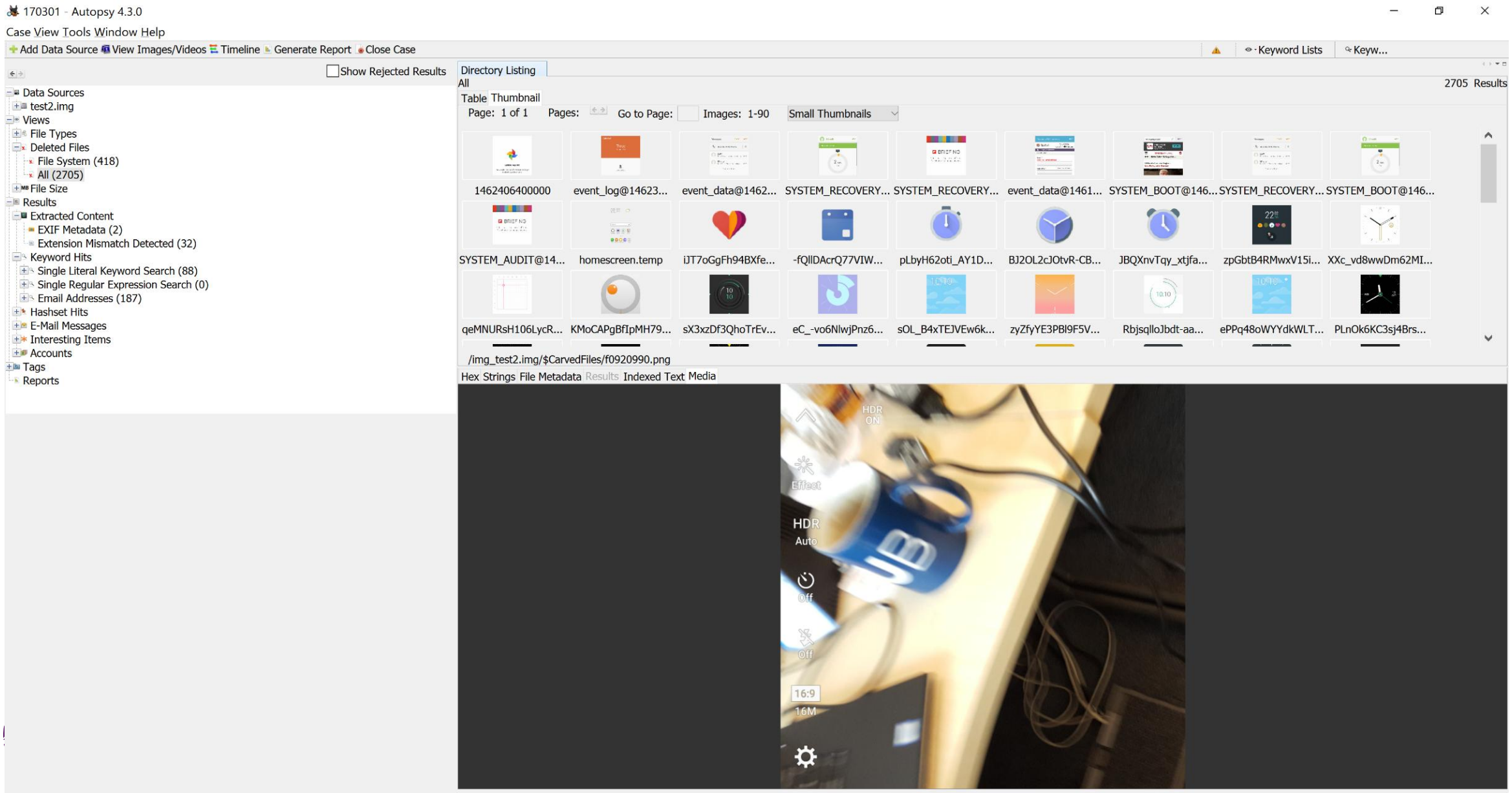
- File type can be determined by extension/metadata/content
- Find suitable viewers for files (native applications do not show everything)
- Look for old (deleted) versions of file – only works if file not overwritten in-place
- Tools often support searching for known hashes and in file contents
  - Known bad: CSAM, other illicit content via Project VIC or CAID
  - Known good: e.g. OS and known applications (https://www.nist.gov/itl/csd/secure-systems-and-applications/national-software-reference-library-nsrl)
  - Keyword search, …

“Undeleting”

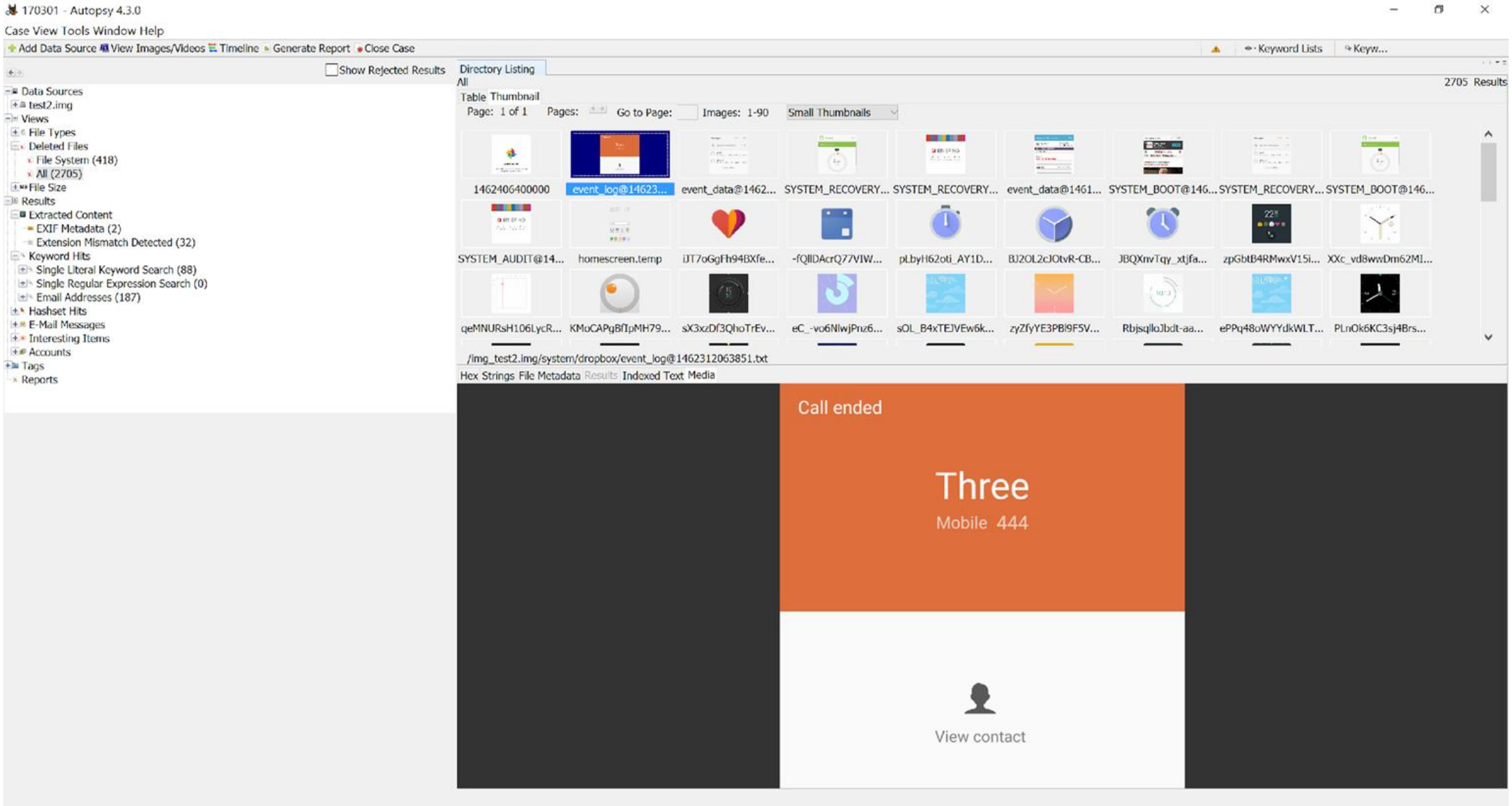
When you delete a file through the OS: blocks get marked as unused, but not wiped/overwritten – hence, “undelete” works if you have an image:



Deleted files can contain interesting info



Deleted files can contain interesting info



Deleted files can contain interesting info

Signal Desktop Analyzer

An add-on ingest module to Autopsy Digital Forensics Platform.

Functionalities

- Decrypts Signal's SQLite database (encrypted with SQLCipher4).
- Parses the database and extracts **contacts**, **messages with attachments** and **call logs**.
- Decrypts the SQLite temporary file WAL (.sqlite-wal) and recovers **recently deleted messages**.

Dependencies

Autopsy 4.19.3 for Windows.

Installation

- Download the directory **SignalDesktopAnalyzer**.
- Place it in Autopsy's python_modules folder. Further details are provided here.

https://github.com/LinahKFM/SignalDesktopAnalyzer

Possible anomalies to watch out for

- **Partition tables with alignment not used by the OS installer:** Maybe the partition was fabricated with another tool
- **Unusual ordering of data on the drive:** Data may have been copied in one go
- **No fragments of old data in the free space:** Drive might have been cleaned and cloned from other system
- **Access pattern of file groups not in sync:** Files put in browser cache, but not the cache index
- **Unusual speed/times:** Files in the download folder downloaded with the speed of a USB3 HDD while user had slow internet connection
- Least significant bits of timer values biased

Memory forensics

RAM dump may contain data never stored to permanent memory, for example:

- Passwords / encryption keys
- Volatile user input (e.g. browser “private” mode)
- Traces of buffer overflows and similar exploits
- RAM-only rootkits / viruses

PERSISTENCE MECHANISM

The Duqu 2.0 malware platform was designed in a way that survives almost
in memory of the infected systems, without need for persistence. To achiev
attackers infect servers with high uptime and then re-infect any machines i
that get disinfected by reboots. Surviving exclusively in memory while runni
level code through exploits is a testimony to the technical prowess of the g



https://volatilityfoundation.org/

Network & log file forensics

Log files assist in:

- Timelines of events, computer usage, …
- Incident response
- Can sometimes contain secret info by accident

Network logs e.g. for

- Illicit activity
- Malware communication
- Exploit traces

Take home messages

- Forensics is well supported by tools nowadays (cmdline and GUI)
- Some hands-on experience in the lab
- There are many commercial tools (e.g. Belkasoft, Cellebrite, …) usually used in practice
- Can be extended with LLMs (be careful about privacy, chain of custody, hallucinations, …)
- **A good forensics tool never modifies the image**
- Next lecture: IoT & embedded devices

Durham University

Thanks! Questions & discussion